

Mise en œuvre de la sécurité informatique

Module 2 : Réseaux, internet et sécurité informatique

Cette fiche d'évaluation synthétique mobilise l'ensemble des notions du chapitre dans des contextes complexes d'analyse, de conception et d'argumentation juridique.

EXERCICE 1 Analyse d'impact et cryptanalyse du chiffre de César

On considère le système d'information d'un hôpital régional gérant les dossiers patients (DPI), le planning des blocs opératoires et la facturation. Trois incidents surviennent :

1. Une panne de courant prolongée rend les serveurs inaccessibles pendant 6 heures.
 2. Un agent administratif modifie frauduleusement le diagnostic d'un patient pour masquer une erreur médicale.
 3. Un rançongiciel chiffre la base de données des DPI ; l'attaquant menace de publier les données sur le dark web si la rançon n'est pas payée.
1. Pour chaque incident, identifiez le(s) critère(s) du triptyque CIA (Confidentialité, Intégrité, Disponibilité) violé(s) et justifiez votre choix en précisant l'impact opérationnel et éthique immédiat.
 2. L'hôpital utilise historiquement un chiffrement de César (décalage $k = 3$) pour obfusquer les mots de passe Wi-Fi des équipements médicaux nomades.
 - (a) Chiffrez le mot de passe `SECU_TI_2025` avec cette clé. Donnez le résultat.
 - (b) Un attaquant intercepte le message chiffré `VHFUHW_VL_D`. Retrouvez le clair sans connaître la clé, en expliquant la méthode mathématique utilisée (espace des clés, force brute).
 - (c) Démontrer formellement pourquoi ce chiffrement ne garantit pas la confidentialité au sens moderne, en calculant la taille de l'espace des clés et en évoquant l'analyse fréquentielle.
 3. Proposez une alternative algorithmique moderne (nom de l'algorithme, taille de clé, mode d'opération) adaptée à des équipements à ressources contraintes (IoT médical), justifiant le choix par rapport aux failles identifiées.

EXERCICE 2 Taxonomie des malwares, ingénierie sociale et cadre juridique camerounais

1. Classifiez les programmes malveillants suivants selon leur mode de propagation, leur charge utile (payload) et leur objectif principal. Complétez le tableau comparatif ci-dessous.

Malware	Propagation	Charge utile	Objectif principal
Ver (Worm)			
Cheval de Troie (Trojan)			
Rançongiciel (Ransomware)			

2. Un courriel de phishing ciblé (spear-phishing) est reçu par le comptable de l'hôpital. L'en-tête technique (simplifié) indique :

```
From: "Direction Financiere" <direction@hopital-cm.local>  
Return-Path: <attacker@malicious-domain.xyz>  
Received: from mail.malicious-domain.xyz (192.0.2.45)  
X-Spam-Status: No, score=2.1
```

Analysez ces en-têtes pour identifier trois indices techniques prouvant la fraude. Expliquez pourquoi le champ `From` est aisément falsifiable (protocole SMTP).

3. La loi n°2010/012 du 21 décembre 2010 relative à la cybercriminalité au Cameroun sanctionne ces actes.
- Citez l'article exact et la peine encourue (emprisonnement et/ou amende) pour l'accès frauduleux à un système d'information (Art. 7).
 - Citez l'article et la peine pour l'interception non autorisée de données informatiques (Art. 10).
 - Qualifiez juridiquement l'acte de l'attaquant qui menace de publier les DPI : s'agit-il d'extorsion, de violation du secret professionnel, ou des deux ? Justifiez en croisant Code Pénal et Loi sur la cybercriminalité.

EXERCICE 3 Conception d'un contrôle d'accès multi-facteurs et biométrie

L'hôpital souhaite sécuriser l'accès physique à la salle des serveurs (baies de brassage, stockage DPI) et l'accès logique au portail d'administration de la base de données.

- Proposez une architecture de contrôle d'accès physique à trois facteurs (Facteur « Ce que je sais », « Ce que j'ai », « Ce que je suis »). Précisez la technologie pour chaque facteur (ex : code PIN, badge RFID, empreinte veineuse).
- Comparez technologiquement le badge RFID (13,56 MHz, ISO 14443) et l'authentification biométrique veineuse (palm vein) sur les critères suivants :
 - Résistance au clonage / usurpation (spoofing).
 - Taux de faux positifs (FAR) et faux négatifs (FRR) : ordres de grandeur typiques.
 - Non-répudiation et traçabilité juridique.

- Hygiène et acceptabilité utilisateur (contexte hospitalier).
3. Pour l'accès logique (portail admin), la politique impose un mot de passe fort. Définissez une politique de complexité (longueur, jeu de caractères, expiration, historique) conforme aux recommandations ANSSI/CNIL adaptées au contexte.
 4. Un administrateur perd son badge RFID. Décrivez la procédure de révocation et de ré-émission immédiate, en intégrant la gestion des listes de contrôle d'accès (ACL) sur le contrôleur de porte et la journalisation (logs) pour l'audit de sécurité.

EXERCICE 4 Stratégie de défense en profondeur : Antivirus, Sauvegarde et Sensibilisation

Face à la menace de rançongiciel (Exercice 1), la DSI doit mettre en œuvre une stratégie de « Défense en profondeur ».

1. Protection antivirale : Comparez l'analyse par signatures (statique) et l'analyse heuristique/comportementale (dynamique/sandbox) pour détecter un rançongiciel zero-day chiffrant les fichiers .sql et .bak. Laquelle est efficace ? Pourquoi l'autre échoue-t-elle initialement ?
2. Stratégie de sauvegarde (Règle 3-2-1) : Déclinez concrètement cette règle pour les DPI (taille 2 To, croissance 500 Go/an, RPO < 1h, RTO < 4h).
 - Support 1 (Production) : ...
 - Support 2 (Site local, hors ligne) : ...
 - Support 3 (Site distant / Cloud souverain) : ...

Expliquez pourquoi une sauvegarde sur un partage réseau SMB monté en permanence sur le serveur de production ne respecte pas la règle du « hors ligne » (air gap logique) face à un rançongiciel wormable.

3. Lutte contre les Fake News et ingénierie sociale : L'hôpital subit une campagne de désinformation sur les réseaux sociaux affirmant que « les données des patients ont été vendues ». Proposez un plan de communication de crise en 3 étapes (Vérification, Communication officielle, Suivi) intégrant la cellule de crise RSSI/DPO/Communication. Quel est le risque juridique si l'hôpital communique trop tard (RGPD / Loi camerounaise sur la protection des données) ?